

Gestión de Riesgos / Asignacion lab 10 (core)

Evaluación de riesgos cibernéticos

Paso 1: Identificación de Activos y Amenazas

1.1 Identificación del Activo Principal

En este escenario, el activo principal es el sistema de banca en línea de la organización financiera. Este sistema permite a los clientes gestionar sus cuentas, realizar transferencias y acceder a otras prestaciones de manera digital.

1.2 Identificación de Amenazas

Para este sistema he identificado cinco amenazas potenciales:

1. **Intento de intrusión o hacking:** un atacante podría intentar acceder al sistema mediante vulnerabilidades en el software.
2. **Ataques de malware:** software malicioso podría infectar el sistema, comprometiendo la seguridad de los datos o afectando la funcionalidad.
3. **Phishing dirigido a los clientes:** los clientes podrían caer en ataques de phishing y revelar sus credenciales, poniendo en riesgo sus cuentas.
4. **Ataque de denegación de servicio (DDoS):** un atacante podría intentar sobrecargar el sistema con múltiples solicitudes para interrumpir el servicio.
5. **Errores de software:** fallos en el código del sistema podrían permitir vulnerabilidades o comprometer el funcionamiento del servicio.

Paso 2: Evaluación Cuantitativa de Riesgos

Métricas para calcular el impacto potencial de cada amenaza:

1. **SLE (Single Loss Expectancy):** Expectativa de pérdida única.
2. **ARO (Annualized Rate of Occurrence):** Tasa anualizada de ocurrencia.
3. **ALE (Annualized Loss Expectancy):** Expectativa de pérdida anualizada.

Fórmulas a Utilizar

- **SLE = Valor del Activo x Factor de Exposición (EF)**
- **ALE = SLE x ARO**

Cálculo para una Amenaza: Intento de intrusión

1. **Valor del Activo:** \$1,000,000 (suponiendo que el sistema de banca en línea tiene un valor crítico).
2. **Factor de Exposición (EF):** 25% (suponiendo que un ataque exitoso podría comprometer un cuarto del sistema).

3. **ARO:** 0.5 (esperamos que ocurra un intento exitoso cada dos años).

Cálculo

- **SLE:** $\$1,000,000 \times 0.25 = \$250,000$
- **ALE:** $\$250,000 \times 0.5 = \$125,000$

Evaluación Cuantitativa de Riesgos para Cada Amenaza

Amenaza 1: Intento de intrusión o hacking

- **Valor del Activo:** \$1,000,000
- **Factor de Exposición (EF):** 25%
- **ARO:** 0.5 (una vez cada dos años)

Cálculos:

- **SLE** = $\$1,000,000 \times 0.25 = \$250,000$
 - **ALE** = $\$250,000 \times 0.5 = \$125,000$
-

Amenaza 2: Malware o Ransomware

- **Valor del Activo:** \$1,000,000
- **Factor de Exposición (EF):** 30%
- **ARO:** 0.8 (esperamos que ocurra 4 veces cada 5 años)

Cálculos:

- **SLE** = $\$1,000,000 \times 0.3 = \$300,000$
 - **ALE** = $\$300,000 \times 0.8 = \$240,000$
-

Amenaza 3: Robo de datos de clientes

- **Valor del Activo:** \$1,000,000
- **Factor de Exposición (EF):** 50%
- **ARO:** 0.2 (esperamos que ocurra una vez cada cinco años)

Cálculos:

- **SLE** = $\$1,000,000 \times 0.5 = \$500,000$
 - **ALE** = $\$500,000 \times 0.2 = \$100,000$
-

Amenaza 4: Fallo en el sistema por error humano

- **Valor del Activo:** \$1,000,000
- **Factor de Exposición (EF):** 10%

- **ARO:** 1.5 (puede suceder hasta 1.5 veces al año)

Cálculos:

- **SLE** = \$1,000,000 x 0.1 = \$100,000
 - **ALE** = \$100,000 x 1.5 = \$150,000
-

Amenaza 5: Ataque de denegación de servicio (DDoS)

- **Valor del Activo:** \$1,000,000
- **Factor de Exposición (EF):** 15%
- **ARO:** 1 (esperamos que ocurra una vez al año)

Cálculos:

- **SLE** = \$1,000,000 x 0.15 = \$150,000
- **ALE** = \$150,000 x 1 = \$150,000

Resumen de Resultados de ALE para Cada Amenaza

Amenaza	Valor del Activo	EF	ARO	SLE	ALE
Intento de intrusión/hacking	\$1,000,000	25%	0.5	\$250,000	\$125,000
Malware o Ransomware	\$1,000,000	30%	0.8	\$300,000	\$240,000
Robo de datos de clientes	\$1,000,000	50%	0.2	\$500,000	\$100,000
Fallo en el sistema (error humano)	\$1,000,000	10%	1.5	\$100,000	\$150,000
Ataque de denegación de servicio (DDoS)	\$1,000,000	15%	1	\$150,000	\$150,000

Conclusiones de la Evaluación Cuantitativa

- La amenaza con el **ALE más alto** es el **Malware o Ransomware**, con un **ALE de \$240,000**.
- La amenaza de **fallo en el sistema por error humano** y el **ataque DDoS** también presentan impactos significativos.

Paso 3: Evaluación Cualitativa de Riesgos

- **Probabilidad:**
 - **Alta:** La amenaza tiene una probabilidad elevada de ocurrir frecuentemente.
 - **Media:** La amenaza podría ocurrir ocasionalmente.
 - **Baja:** La amenaza es poco probable.
- **Impacto:**
 - **Alto:** La amenaza podría causar daños significativos a la organización.
 - **Medio:** La amenaza podría causar daños moderados.
 - **Bajo:** La amenaza causaría daños menores.

Utilizaremos estas categorías para cada amenaza identificada en los pasos anteriores.

Amenaza 1: Intento de intrusión o hacking

- **Probabilidad:** Media (ocurre una vez cada dos años)
- **Impacto:** Alto (posible pérdida de acceso y daños financieros)
- **Nivel de Riesgo:** Medio-Alto

Amenaza 2: Malware o Ransomware

- **Probabilidad:** Alta (ocurre 4 veces cada 5 años)
- **Impacto:** Alto (riesgo de pérdida significativa de datos y de costos de recuperación)
- **Nivel de Riesgo:** Alto

Amenaza 3: Robo de datos de clientes

- **Probabilidad:** Baja (una vez cada cinco años)
- **Impacto:** Alto (compromiso de la confidencialidad de datos sensibles)
- **Nivel de Riesgo:** Medio

Amenaza 4: Fallo en el sistema por error humano

- **Probabilidad:** Alta (1.5 veces al año)
- **Impacto:** Medio (daño en el sistema, interrupción temporal)
- **Nivel de Riesgo:** Medio

Amenaza 5: Ataque de denegación de servicio (DDoS)

- **Probabilidad:** Media (una vez al año)
 - **Impacto:** Medio (interrupción temporal del servicio)
 - **Nivel de Riesgo:** Medio
-

Resumen de la Evaluación Cualitativa de Riesgos

Amenaza	Probabilidad	Impacto	Nivel de Riesgo
Intento de intrusión/hacking	Media	Alto	Medio-Alto
Malware o Ransomware	Alta	Alto	Alto
Robo de datos de clientes	Baja	Alto	Medio
Fallo en el sistema (error humano)	Alta	Medio	Medio
Ataque de denegación de servicio (DDoS)	Media	Medio	Medio

Conclusiones de la Evaluación Cualitativa

A partir de esta evaluación, podemos observar que:

- **Malware o Ransomware** representa el riesgo cualitativo más alto debido a su alta probabilidad de ocurrencia y su impacto.
- **Intentos de intrusión y hacking** también son una amenaza considerable, ubicándose en el rango de **riesgo medio-alto**.

Paso 4: Mitigación de Riesgos

Amenaza 1: Intento de intrusión o hacking

- **Medida de Mitigación:**
 - Implementar **firewalls** y sistemas de **detección y prevención de intrusiones (IDS/IPS)** para monitorear y bloquear accesos no autorizados.
 - Establecer una política de **gestión de acceso** que incluya autenticación multifactor (MFA) para usuarios con acceso privilegiado.
 - Realizar **auditorías de seguridad** periódicas para identificar y corregir vulnerabilidades en la red y aplicaciones.
 - **Justificación:** Estas medidas ayudan a reducir la probabilidad de acceso no autorizado y permiten detectar y responder rápidamente ante intentos de intrusión, protegiendo los sistemas y datos sensibles.
-

Amenaza 2: Malware o Ransomware

- **Medida de Mitigación:**
 - Implementar un **software antivirus y antimalware** actualizado en todos los dispositivos de la red.
 - Realizar **copias de seguridad** de los datos de forma regular y asegurarse de que estén almacenadas en un entorno aislado y seguro.
 - Capacitar a los empleados sobre los riesgos de **phishing** y **descarga de archivos sospechosos**, para reducir la posibilidad de ataques de ingeniería social.
 - **Justificación:** Estas acciones no solo previenen la infección, sino que también permiten una rápida recuperación en caso de un ataque de ransomware, minimizando el impacto sobre las operaciones de la organización.
-

Amenaza 3: Robo de datos de clientes

- **Medida de Mitigación:**
 - Utilizar **cifrado de datos** para proteger la información de clientes, tanto en tránsito como en reposo.
 - Implementar controles de **acceso basados en roles (RBAC)**, asegurando que solo el personal autorizado tenga acceso a datos sensibles.
 - Realizar **auditorías de acceso** para detectar y revisar accesos sospechosos o no autorizados a los datos de los clientes.
 - **Justificación:** El cifrado y los controles de acceso protegen los datos de clientes contra robo y fuga, y la auditoría permite identificar y corregir rápidamente cualquier acceso no autorizado.
-

Amenaza 4: Fallo en el sistema por error humano

- **Medida de Mitigación:**

- Implementar procedimientos de **capacitación regular** para empleados, centrados en la gestión segura del sistema y la prevención de errores comunes.
 - Establecer **procedimientos de control y revisión** antes de realizar cambios críticos en el sistema.
 - Configurar **copias de seguridad automáticas** y restauración de datos para mitigar el impacto de errores humanos en el sistema.
 - **Justificación:** La capacitación y los procedimientos de control reducen la probabilidad de errores humanos, mientras que las copias de seguridad aseguran la continuidad operativa en caso de fallo.
-

Amenaza 5: Ataque de denegación de servicio (DDoS)

- **Medida de Mitigación:**

- Utilizar un **servicio de protección contra DDoS** para filtrar y bloquear tráfico malicioso dirigido a la infraestructura de la organización.
- Implementar **sistemas de balanceo de carga** que distribuyan el tráfico de red y eviten sobrecargas en un único punto.
- Realizar **pruebas de resistencia** periódicas para evaluar la preparación de la organización frente a ataques DDoS.
- **Justificación:** La protección DDoS y el balanceo de carga garantizan que el sistema esté preparado para manejar grandes volúmenes de tráfico, minimizando las posibilidades de interrupción del servicio.

Paso 5: Informe Final: Evaluación de Riesgos Cibernéticos

1. Introducción

Objetivo del Informe

Este informe tiene como objetivo evaluar los riesgos cibernéticos asociados al sistema de banca en línea, una organización financiera. A través de esta evaluación, se busca identificar amenazas críticas y proponer medidas de mitigación que garanticen la seguridad de los datos sensibles de los clientes y la continuidad del servicio.

Descripción del Activo Principal

El activo principal evaluado en este análisis es el sistema de banca en línea. Este sistema es fundamental para las operaciones diarias, permitiendo a los clientes gestionar sus cuentas, realizar transferencias y acceder a sus estados financieros. Dado su papel central, es esencial proteger este sistema contra posibles amenazas cibernéticas.

2. Identificación de Activos y Amenazas

Resumen de Amenazas Identificadas

1. Intento de Intrusión

- Descripción: Acceso no autorizado al sistema a través de técnicas de hacking.

2. Malware

- Descripción: Software malicioso que puede comprometer el sistema, incluyendo virus y troyanos.

3. Robo de Datos

- Descripción: Robo de información sensible de los clientes y de la organización.

4. Error Humano

- Descripción: Fallos humanos que resultan en la exposición de datos o comprometen la seguridad del sistema.

5. Ataque DDoS

- Descripción: Ataques de Denegación de Servicio Distribuido que buscan interrumpir el acceso al sistema.

Impacto Potencial y Factores de Exposición

Cada amenaza mencionada tiene el potencial de causar pérdidas financieras, afectar la reputación de la organización y comprometer la privacidad de los datos de los clientes.

3. Evaluación Cuantitativa de Riesgos

Cálculo del SLE, ARO y ALE

1. Intento de Intrusión

- SLE: \$50,000

- **ARO:** 0.5 (una vez cada dos años)
- **ALE:** \$25,000

2. Malware

- **SLE:** \$30,000
- **ARO:** 0.8 (aproximadamente una vez al año)
- **ALE:** \$24,000

3. Robo de Datos

- **SLE:** \$70,000
- **ARO:** 0.3 (aproximadamente una vez cada tres años)
- **ALE:** \$21,000

4. Error Humano

- **SLE:** \$20,000
- **ARO:** 1.0 (una vez al año)
- **ALE:** \$20,000

5. Ataque DDoS

- **SLE:** \$60,000
- **ARO:** 0.4 (aproximadamente una vez cada dos años y medio)
- **ALE:** \$24,000

Interpretación de Resultados

Los valores calculados reflejan el impacto financiero potencial de cada amenaza. Los intentos de intrusión y los ataques DDoS presentan altos riesgos financieros, mientras que los errores humanos, aunque de menor impacto unitario, son más frecuentes y deben ser mitigados con controles adecuados.

4. Evaluación Cualitativa de Riesgos

Amenaza	Nivel de Riesgo	Justificación
Intento de Intrusión	Alto	Alta probabilidad de impacto en la seguridad.
Malware	Medio	Riesgo moderado con potencial para causar daño.
Robo de Datos	Alto	Puede comprometer la confidencialidad de los datos.
Error Humano	Medio	Frecuencia elevada, pero el impacto es menor.
Ataque DDoS	Alto	Alta capacidad de interrumpir servicios.

5. Medidas de Mitigación de Riesgos

1. Intento de Intrusión

- **Medidas:** Implementar sistemas de detección de intrusos (IDS) y autenticación multifactor.
- **Justificación:** Estos sistemas ayudarán a detectar y prevenir accesos no autorizados.

2. Malware

- **Medidas:** Instalar software antivirus y realizar copias de seguridad periódicas.
- **Justificación:** La detección temprana y la capacidad de restaurar datos son esenciales para mitigar ataques de malware.

3. Robo de Datos

- **Medidas:** Aplicar cifrado de datos y monitoreo de accesos.
- **Justificación:** El cifrado protege los datos sensibles, y el monitoreo detecta accesos no autorizados.

4. Error Humano

- **Medidas:** Realizar capacitaciones en seguridad y establecer protocolos de acceso.
- **Justificación:** La educación y los procedimientos ayudan a reducir la frecuencia de errores humanos.

5. Ataque DDoS

- **Medidas:** Implementar servicios de mitigación de DDoS y balanceadores de carga.
- **Justificación:** Estos servicios ayudan a asegurar la disponibilidad del sistema frente a ataques DDoS.

6. Conclusiones y Recomendaciones

Resumen del Análisis

El análisis realizado demuestra que el sistema de banca en línea enfrenta riesgos significativos de seguridad, especialmente en cuanto a intentos de intrusión y ataques DDoS. Las amenazas de malware y robo de datos también representan riesgos serios, que deben ser mitigados adecuadamente.

Recomendaciones Finales

Se recomienda implementar un sistema de monitoreo continuo y revisar políticas de acceso regularmente. Además, es esencial fortalecer la cultura de seguridad dentro de la organización mediante capacitaciones periódicas y la implementación de controles técnicos avanzados.